Preserving Digital Evidence from a Suspected Compromised Laptop

A Safe First-Responder Workflow

Author	Prathmesh Humane (Intern ID 2414)
Organisation	RedKross Research Foundation, Internship Programme (October 2026 batch)
Task	Digital Forensics Basics
Version	1.0, October 2026
Audience	IT support staff, lab assistants and team leads who reach a suspect laptop first. Not intended for trained forensic examiners.

1. Purpose

This guide tells the first person to reach a suspected compromised laptop what to do in the first hour. Their job is to keep the evidence in the state they found it, to write down everything they see and do, and to hand the device over with an unbroken chain of custody.

The guide does **not** teach forensic analysis. The most useful thing a first responder can do is avoid destroying evidence that a trained examiner will need later.

2. Scope and Audience

In scope	Out of scope
A single Windows, macOS or Linux laptop suspected of compromise (malware, unauthorised access, data theft)	Mobile phones, servers, cloud accounts and network devices
Organisation-owned devices, or devices whose owner has given written permission	Any device you are not authorised to handle. **Never collect data from another person's device without authority.**
Recording observations, isolating the laptop, protecting it, hashing and chain of custody	Memory capture, disk imaging and analysis. These are performed only by trained personnel and are referenced here only so you know when to call them.

The worked example in this repository uses a Windows 11 laptop. The same principles apply to other operating systems.

3. Introduction: Why Preservation Comes First

Digital evidence is fragile. Every action on a running computer changes something: opening a folder updates access times, logging in creates event-log entries, and "Shut down" in Windows 11 with Fast Startup writes part of memory to disk. Some evidence disappears on its own. Running processes, open network connections and decryption keys exist only in memory and are lost when power is removed. RFC 3227 calls this the *order of volatility*: the most short-lived evidence should be protected first [1], [2]. International guidance (ISO/IEC 27037) divides evidence handling into identification, collection, acquisition and preservation [3]. This guide covers the first-responder parts of identification, collection and preservation.

Evidence that has been changed or poorly documented may not be trusted later, whether in an internal investigation, a disciplinary process or a court. In India, a certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023 must accompany electronic records submitted as evidence. The certificate includes the record's **hash value**, so careful hashing and documentation have direct legal relevance [4].

Four widely used principles from the UK ACPO *Good Practice Guide for Digital Evidence* summarise the approach [5]:

1. Do not change data that may later be relied upon.
2. If original data must be accessed, the person doing it must be competent and able to explain their actions.
3. Keep an audit trail that lets an independent person repeat the process and reach the same result.
4. The person in charge is responsible for making sure these principles are followed.

4. Five Ground Rules

#	Rule	Why it matters
1	**Don't make it worse.** Stop damage, but don't "investigate" on the device.	Every click changes evidence.
2	**Record before you touch.** Photograph and write first, act second.	Your notes become the only record of the original state.
3	**Touch as little as possible.** Every interaction must have a reason, and you must log it.	It keeps the number of changes small and explainable (ACPO Principle 2).
4	**Protect the original.** Analysis happens on verified copies, never on the original.	The original can be re-examined later.
5	**Account for every hand-off.** Who had it, when and why, with signatures.	It proves the evidence was not tampered with (chain of custody).

5. Before You Touch Anything: Authority, Safety and Kit

Authority. Confirm that you are authorised to act: the device belongs to the organisation, or its owner has given written consent, and the incident lead has asked you to respond. Write down who authorised you and when.

Safety. If there is any physical risk (damaged battery, swelling, smoke, heat), stop and follow the organisation's physical-safety procedure first. People come before evidence.

First-responder kit.

- A camera or phone for photographs. Use a work device if possible, and record which device you used.
- A bound notebook and pen. A bound notebook makes it obvious if pages are missing.
- A reliable time reference, such as a phone on network time.
- Evidence bags (anti-static for electronics), tamper-evident seals or tape, and labels.
- Blank chain-of-custody forms (see `templates/`).
- Gloves. A Faraday bag is optional.

6. The Workflow at a Glance

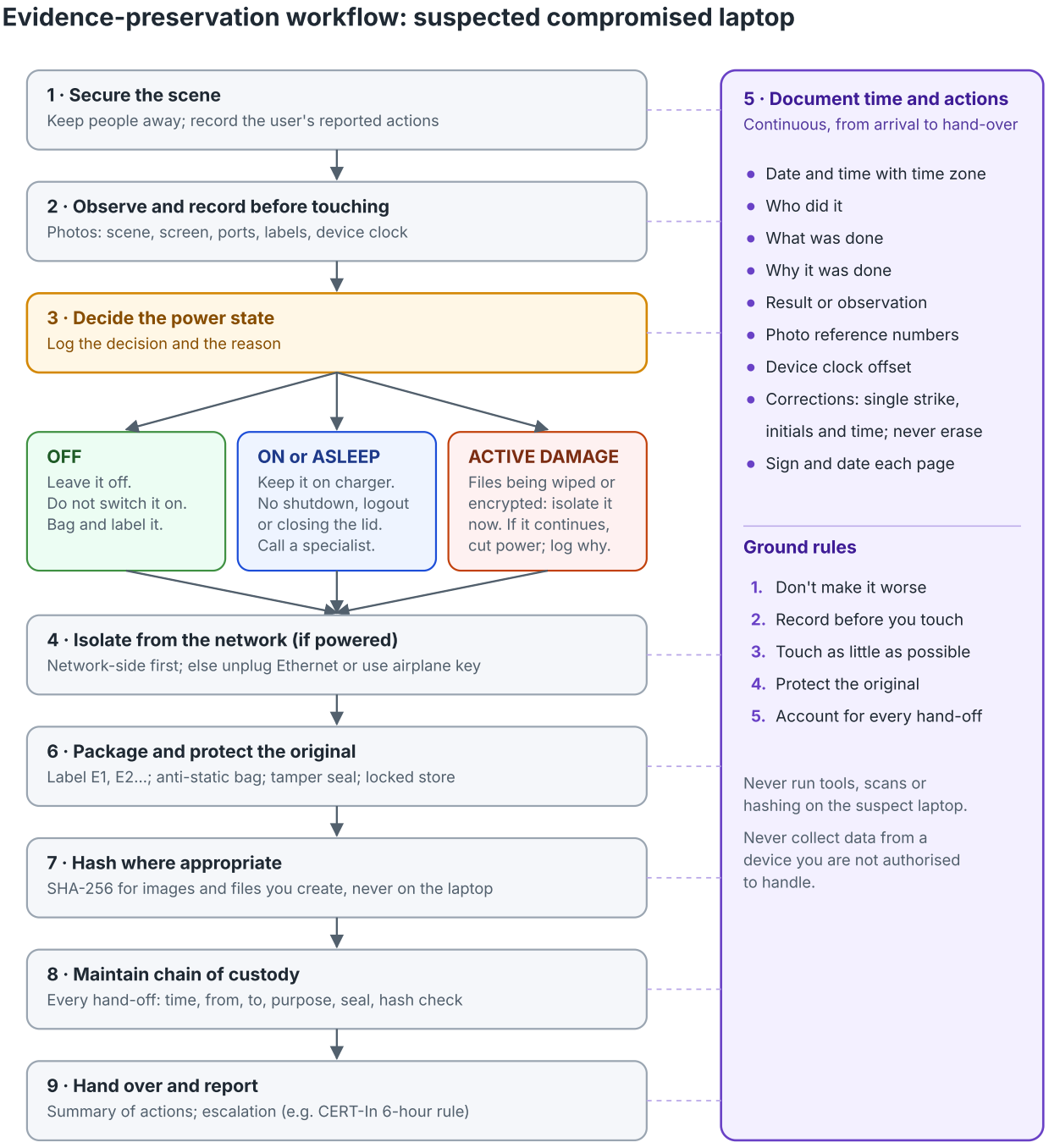


Figure 1. The nine-step workflow. The action log (Step 5) runs from the moment you arrive until hand-over.

7. Step-by-Step Workflow

Step 1: Secure the scene

- Keep other people away from the laptop, including the user. Do not let the user log in "to show you", delete anything or "clean up".

- Ask the user, without touching the device, what they noticed, when, and what they have already done (for example, "I closed the browser"). Record these as **reported** actions, not your own.
- Note other items that may matter: USB drives, external disks, the charger, and any written notes or passwords left nearby. Do not plug any of them in anywhere.

Step 2: Observe and record

Photograph and write **before** touching anything. Capture:

What to record	Detail
Overall scene	Desk, laptop position and connected cables, from several angles
Screen	Whatever is displayed: open windows, error messages, pop-ups or ransom notes
Power state	On, off, or sleeping (screen dark but power LED pulsing or fans running). **Treat sleep as ON** [6].
Connections	Ethernet cable, Wi-Fi icon, Bluetooth, USB devices, docking station, charger
Identifiers	Make, model, serial number, asset tag, colour, and any visible damage
Device clock	The time shown on the laptop compared with your reference clock, and the difference between them

Number each photo and list it in your notes (photo number, time, description).

Step 3: Decide on the power state

The power decision is the most important call a first responder makes. Use this table, and log both your decision and your reason.

Situation	Action	Reason
Laptop is OFF	Leave it off. Do not switch it on.	Powering on changes data on the disk [6].
Laptop is ON (or asleep), no visible destruction	Do **not** shut down, restart, log out or close the lid. Connect its own charger so it does not run flat. Isolate it from the network (Step 4). Call the incident lead or a trained examiner to decide on memory capture.	Memory holds running processes, network connections and encryption keys that are lost at power-off [2]. If BitLocker or device encryption is on, powering off may lock the disk.
Laptop is ON and data is actively being destroyed (for example, files visibly being encrypted or wiped)	Isolate it from the network immediately. If destruction continues, remove power: unplug the charger, then remove the battery if it is removable. If not, hold the power button until it switches off. Record the exact time and your reason.	Stopping further loss outweighs losing memory contents. Use a forced power-off rather than "Shut down", which writes to disk [6].

> **Encryption check:** Ask the IT administrator, without touching the laptop, whether BitLocker or device encryption is enabled and where the recovery key is stored (for example, the organisation's directory service). Record the answer and its source. Never write the key itself in your notes or this repository.

Step 4: Isolate from the network

The aim is to stop an attacker from reaching the laptop or deleting data remotely, using the smallest possible interaction.

1. **Prefer network-side isolation.** Ask IT to disable the switch port or block the device at the Wi-Fi access point. This does not touch the laptop at all.

2. Otherwise, **unplug the Ethernet cable** and photograph it first.
3. If Wi-Fi must be turned off on the device, use the **physical airplane-mode key** or a single system-tray action, as instructed by the incident lead. Log it.
4. A Faraday bag blocks radio signals, but a charging cable running into the bag can defeat it, and the laptop may drain its battery searching for a signal. Use one only if your procedure says so.

Do **not** unplug the charger (unless destruction is ongoing), close the lid, run antivirus or open files.

Step 5: Document time and actions

Keep a **contemporaneous action log**: write each entry at the time it happens, not from memory afterwards. Every entry needs:

Field	Example
Date and time with time zone	2026-10-14 10:47 IST (UTC+05:30)
Who	R. Kale (Lab Assistant)
Action	Unplugged Ethernet cable from laptop port
Reason	Network isolation per incident lead instruction
Result or observation	Network icon changed to "No internet". Photo P-07 taken.

Rules for the log:

- **Record the clock offset.** For example: "Laptop clock shows 10:44. Reference shows 10:47. Laptop is 3 minutes slow." Examiners use this to line up file and log timestamps.
- **Never erase.** Correct a mistake with a single line through it, then add your initials and the time.
- Leave no blank lines. Draw a line through unused space.
- Sign and date each page.

Step 6: Package and protect the original

- Label the laptop, charger and any removable media with an **evidence item number** (E1, E2, and so on).
- If the laptop must stay powered for a specialist, keep it on its charger in a secure location until they arrive.
- Once the laptop is powered off (by a specialist or by an earlier decision), place it in an anti-static evidence bag and seal it with **tamper-evident tape**. Write the seal number on the chain-of-custody form, and sign across the seal.
- Store it in a locked location with restricted, logged access.
- Never connect removable media found at the scene to another computer. Imaging is done only by trained staff using a **write blocker**, which lets them read the drive without changing it.
- All analysis happens on **verified copies** (forensic images). The original stays sealed.

Step 7: Use hashes where appropriate

A **cryptographic hash** is a fixed-length "fingerprint" calculated from data. Changing even one bit of the data produces a completely different hash. Hashes prove that a copy is identical to the original and that nothing has changed since the hash was taken.

Which algorithm. Use **SHA-256**, a NIST-approved algorithm defined in FIPS 180-4 [7]. MD5 and SHA-1 have known collision weaknesses. NIST is retiring SHA-1 [8]. Record MD5 or SHA-1 only *in addition to* SHA-256, if older tools require them [9].

When hashing is appropriate:

- Forensic images of memory or disk: hashed by the examiner at acquisition and verified after every copy.
- Files you create during the response, such as scene photographs and the exported action log. Hash them when you copy them off your camera or phone.
- Any file handed over on removable media: hash before transfer, then verify on receipt.

When it is NOT appropriate: Do **not** run hashing tools on the suspect laptop itself. Running any program on a live system changes it (memory, prefetch files, access times). Hashing the original disk is the examiner's job during imaging, through a write blocker.

Where to record hashes. Record each hash in the chain-of-custody form (algorithm, value, what was hashed, who computed it and when), and keep a second copy somewhere that cannot be altered. A printed copy held by the incident lead is one example [9].

What a hash does not prove:

- It cannot show that the data was unchanged *before* it was hashed. Only your notes can do that.
- A file's hash covers its **content**, not file-system details such as "last modified" times. Those are preserved by imaging the whole disk and by your documentation. The hash demo in `lab/hash-demo/` shows this.

Step 8: Maintain chain of custody

Chain of custody is the documented, unbroken record of who had each evidence item, when, where and why, from seizure to final disposal. A gap in that record is a reason to doubt the evidence.

For every transfer, record:

- Date and time, with time zone
- Released by (name and signature)
- Received by (name and signature)
- Purpose of the transfer
- Seal number, and whether the seal was intact
- Whether the hash was verified, where applicable
- Storage location after the transfer

Use the blank template in `templates/chain-of-custody-template.docx` (also available as Markdown and PDF). One form covers one evidence item.

Step 9: Hand over and report

- Hand the evidence and your notes to the incident lead or forensic examiner. Record the hand-over on the chain-of-custody form.
- Write a short summary: what was reported, what you observed, what you did and why, and what you did **not** do.
- Escalate according to policy. Organisations in India may have a legal duty to report certain cyber incidents to CERT-In **within 6 hours** of noticing them under the CERT-In Directions of 28 April 2022 [10]. The incident lead decides this, but your timestamps make it possible. Evidence handling is one part of the wider incident-response process described in NIST SP 800-61 Rev. 3 [11].

8. Common Mistakes

Don't	Do instead
Shut down via the Start menu "to be safe"	Follow the power-state table in Step 3
Run an antivirus scan or "quick check"	Leave analysis to the examiner. Scans change and may delete evidence.
Browse folders or open suspicious files	Photograph what is already on screen
Plug your USB drive in to copy files	Wait for imaging with a write blocker
Let the user log in or "fix" it	Record what the user says they did
Close the lid to carry it	Keep it open and powered until a decision is made
Forward the phishing email "for analysis"	Leave the mailbox untouched and tell the incident lead
Write notes from memory at the end of the day	Write each action as it happens

9. One-Page Quick Checklist

- [ ] Authority confirmed and recorded (who, when)
- [ ] Scene secured, user statement recorded as "reported actions"
- [ ] Photos taken: scene, screen, ports, labels, clock
- [ ] Power state recorded; decision and reason logged
- [ ] Encryption status and recovery-key location asked (key not written down)
- [ ] Network isolated with minimal interaction; method logged
- [ ] Device clock offset recorded
- [ ] Action log kept contemporaneously, signed per page
- [ ] Items labelled (E1, E2…), bagged, sealed; seal numbers recorded
- [ ] Hashes (SHA-256) recorded for all files created or transferred
- [ ] Chain-of-custody form started for each item; every hand-off signed
- [ ] Hand-over completed; summary written; escalation decision recorded

10. Conclusion

A first responder rarely solves the incident, but can easily ruin the investigation. The workflow in this guide is about restraint and records: record before you touch, make only the changes you can justify, protect the original, prove integrity with hashes, and account for every hand-off. Following it keeps the evidence usable for whoever investigates next, whether that is an internal team, an external examiner or a court.

References

[1] D. Brezinski and T. Killalea, "Guidelines for Evidence Collection and Archiving," RFC 3227 / BCP 55, IETF, Feb. 2002. https://www.rfc-editor.org/rfc/rfc3227

[2] K. Kent, S. Chevalier, T. Grance and H. Dang, *Guide to Integrating Forensic Techniques into Incident Response*, NIST SP 800-86, Aug. 2006. https://doi.org/10.6028/NIST.SP.800-86

[3] ISO/IEC 27037:2012, *Information technology: Security techniques: Guidelines for identification, collection, acquisition and preservation of digital evidence*. https://www.iso.org/standard/44381.html

[4] "Supreme Court Rejects Challenge To S.63(4) BSA Mandating Hash Value Disclosure For Electronic Evidence," *LiveLaw*, May 2026. https://www.livelaw.in/top-stories/supreme-court-rejects-challenge-to-s63 4-bsa-mandating-hash-value-disclosure-for-electronic-evidence-535950

[5] Association of Chief Police Officers (ACPO), *Good Practice Guide for Digital Evidence*, Version 5, Mar. 2012.

[6] Scientific Working Group on Digital Evidence (SWGDE), *Best Practices for Digital Evidence Collection*, 18-F-002, Version 1.0, July 2018. https://www.swgde.org/documents/published-complete-listing/18-f-002-swgde-best-practices-for-digital-evidence-collection/

[7] NIST, *Secure Hash Standard (SHS)*, FIPS PUB 180-4, Aug. 2015. https://doi.org/10.6028/NIST.FIPS.180-4

[8] NIST, "NIST Retires SHA-1 Cryptographic Algorithm," news release, Dec. 2022. https://www.nist.gov/news-events/news/2022/12/nist-retires-sha-1-cryptographic-algorithm

[9] B. Guttman, D. R. White and T. Walraven, *Digital Evidence Preservation: Considerations for Evidence Handlers*, NIST IR 8387, Sept. 2022. https://doi.org/10.6028/NIST.IR.8387

[10] CERT-In, Directions under sub-section (6) of Section 70B of the Information Technology Act, 2000, No. 20(3)/2022-CERT-In, 28 Apr. 2022. https://www.cert-in.org.in/

[11] A. Nelson, S. Rekhi, M. Souppaya and K. Scarfone, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*, NIST SP 800-61 Rev. 3, Apr. 2025. https://doi.org/10.6028/NIST.SP.800-61r3